Authenticated phishing campaign kit

JP Carpenter

Authenticated phishing campaign kit

Author: JP Carpenter · https://jpcarpenter.com
Working template · Not legal advice
Companion lesson: https://jpcarpenter.com/tutorials/authenticated-phishing

Fill before rollout: `[Company]` · `[Report channel]` · `[Security owner]` · `[Escalation path]`

---

1. Campaign brief (one page)

Field	Fill
Company	[Company]
Campaign name	Authenticated phishing still wins
Audience	All staff with email access
Owner	[Security owner]
Timing	[Date / window]
Success metric	Staff can name one action when auth passes but the ask is wrong (verify OOB / report / escalate)
Report channel	[Report channel]
Escalation path	[Escalation path]

Purpose: Teach the hard case — SPF/DKIM/DMARC pass and the message can still be malicious (compromised mailbox, lookalike domain, abused platform).

Honest limits: Awareness lesson and rollout kit only. Not a live phishing simulation. Does not replace mail filtering, MFA, or incident response.

---

2. Facilitator talk track (5–10 minutes)

1. **Open (1 min):** “Authentication answers ‘did this come from the claimed domain?’ It does not answer ‘is this safe?’”

2. **Show the gap (2 min):** Compromised real accounts, lookalike domains, abused platforms — all can pass SPF/DKIM/DMARC.
3. **Run or replay the drill (3–4 min):** Mark red flags; choose verify / report / escalate — never “auth passed so click.”
4. **Localize (1–2 min):** Point to `[Report channel]`, `[Security owner]`, `[Escalation path]` for money or access asks.
5. **Close (1 min):** Pause on urgency + secrecy + unfamiliar hosts. Verify out of band. Preserve the original message.

---

3. Learner acknowledgment / roster

Name	Team	Date completed	Ack (initials)	Notes

I completed the authenticated phishing lesson and know how to reach `[Report channel]` / `[Security owner]`.

---

4. Post-campaign checklist

- ☐ Roster filed with awareness records
- ☐ `[Report channel]` tested / confirmed staff can find it
- ☐ High-risk teams (finance, ops) briefed on `[Escalation path]`
- ☐ Lesson link retained for new-hire onboarding
- ☐ Gaps noted for mail filtering / MFA / process owners (not “training will fix it”)
- ☐ After-action notes: what confused people, what to clarify next run

---